AEGIS LAB

SECURITY ENGINEERING PORTFOLIO

웹 취약점 진단 결과 분석·개선 관리

김재민

정보보안 포트폴리오 / v0.2 / 2026.10

허가된 진단 결과를 입력받아 위험을 정리하고,
패치와 재검증의 근거까지 연결하는 웹 프로토타입.

03	45	00
격리 환경 실습 사례	통과한 자동 테스트	실습 외부 네트워크 요청

WHAT THIS PROJECT DEMONSTRATES

증거를 바탕으로 설명하는 분석

재현 조건, 원인, 영향, 수정 전후 응답을 한 흐름으로 정리합니다.

정상 기능을 보존하는 개선

차단 여부와 함께 본인 주문 조회·정상 검색의 회귀 결과를 남깁니다.

한계를 명시한 결과 전달

자체 점수, 합성 데이터, AI 지원 범위를 구분해 설명합니다.

검증: Codex 자동 실행 · 사용자 독립 실습과 브라우저 검증은 확인 전

01 / SYSTEM DESIGN

분석과 검증의 경계

웹앱은 입력된 결과를 정리합니다. 취약점 재현은 별도의 프로세스 내부 실습에서 수행합니다.



주요 설계 선택

선택	목적과 대가
정적 웹 + 브라우저 처리	외부 분석 API 없이 동작. 기업용 중앙 감사 로그는 제공하지 않음.
규칙 기반 점수·권고	계산과 근거를 설명 가능. 자동 취약점 판정과 LLM 진단은 없음.
취약·수정 모드 비교	동일 조건의 전후 결과를 확보. 운영 환경 전체를 재현하지는 않음.
선택적 로컬 저장	기본은 임시 보관. 사용자 장치의 저장소 접근 통제는 별도 필요.

02 / CASE STUDY 01

접근 제어: 인증 이후의 소유권 확인

LAB-001 · high · 인증 완료 테스트 주체가 다른 사용자의 주문을 조회하는 상황

재현 조건

프로세스 내부에서 alice 주체로 GET /api/orders/202를 호출했습니다. 주문 202의 소유자는 bob입니다. 인증은 테스트 fixture이며 인가 검사만 평가합니다.

BEFORE

200 OK

owner: bob
item: Private sample order

AFTER

403 Forbidden

error: forbidden
소유자와 주문 내용은 응답에서 제외

원인과 수정

인증만 확인하고 리소스 소유권은 검사하지 않았습니다. 응답 전에 소유자와 인증 주체를 비교하도록 수정했습니다.

```
elif self.patched and order["owner"] != actor:
    status, result = "403 Forbidden", {"error": "forbidden"}
```

회귀 검증

확인 항목	수정 후 결과
다른 사용자 주문 조회	403, owner와 item 미노출
본인 주문 조회	alice와 bob 모두 200 유지
미인증 / 없는 주문	각각 401 / 404

분류 근거: 합성 주문의 기밀성 영향이 재현되어 high로 분류. 운영 데이터의 민감도·노출 범위는 별도 평가 대상입니다. [1]

03 / CASE STUDY 02

SQL 인젝션: 명령과 데이터 분리

LAB-002 · high · 검색 문자열이 SQL 조건을 변경해 비공개 합성 레코드를 노출

재현 조건

공개 상품 2건과 비공개 상품 1건을 SQLite 메모리 DB에 넣었습니다. 고정된 테스트 문자열을 검색 값으로 전달해 공개 범위 조건의 우회를 확인했습니다.

```
Test input: %' OR 1=1 --

# Before: direct string interpolation
... WHERE public=1 AND name LIKE '%{term}%'
```

검증 항목	수정 전	수정 후
조건 우회 입력	3건 / 비공개 포함	0건 / 미노출
정상 검색: Desk	공개 상품 1건	공개 상품 1건 유지
작은따옴표 포함 입력	구문 오류 가능	200 / 데이터로 처리

수정 코드

```
rows = db.execute(
    "SELECT id,name FROM products WHERE public=1 AND name LIKE ?",
    ("%" + term + "%",)
).fetchall()
```

매개변수 바인딩으로 SQL 문장과 입력 데이터를 분리했습니다. 정상 검색, 빈 검색과 작은따옴표 입력도 검증했습니다. [2]

평가 범위: 메모리 DB의 조회 동작만 검증했습니다. 데이터 수정·삭제, 실제 DB 권한 상승, 운영 시스템 침해를 시험한 사례가 아닙니다.

04 / CASE STUDY 03

세션 쿠키: 응답 정책의 명시

LAB-003 · medium · 인증된 테스트 주체에 대한 합성 쿠키의 보호 속성 검사

확인한 응답

```
# Before
lab_session=SYNTHETIC_ONLY; Path=/

# After
lab_session=SYNTHETIC_ONLY; Path=/;
Secure; HttpOnly; SameSite=Lax
```

속성	수정 전	수정 후
Secure	누락	명시
HttpOnly	누락	명시
SameSite	누락	Lax
Path	/	/ 유지

설계 이유

Secure와 HttpOnly를 명시하고 SameSite=Lax를 적용했습니다. SameSite 정책은 서비스의 로그인·외부 연동 흐름에 맞게 검토해야 합니다. 실제 세션에는 만료·재발급·무효화 등 추가 통제가 필요합니다. [3]

검증의 한계

응답 헤더와 미인증 발급 거부만 확인했습니다. 실제 브라우저의 쿠키 전송·JavaScript 접근 제한, TLS 연결, 세션 탈취 재현은 수행하지 않았습니다.

05 / VALIDATION

통과 수치와 검증 범위를 함께

실행 로그와 생성 시각, 소스 해시를 evidence/에 보관했습니다. 원격 CI 실행 실적은 아닙니다.

45 자동 테스트 통과 — 31 JavaScript + 14 Python

검증 영역	수	주요 확인 내용
입력·점수 모델	14	경계값, 상태 변경, 재검증 기록 필수
UI 이벤트 어댑터	12	입력·검색·업로드·저장·다운로드
사례 데이터 연결	5	소스 해시, 점수, 확인 후 전달, 실패 처리
로컬 보안 실습	14	인가 5 / SQL 5 / 쿠키 4

점수 계산

100 - (10 + 10 + 5) = 75

high 2건, medium 1건을 반영한 실습 점수입니다. 세 건의 조치와 재검증 기록을 포함한 데이터는 100점입니다. 자체 가중치로 계산하며 CVSS와 구분합니다.

수치가 설명하지 않는 것

실제 브라우저 렌더링과 사이트 로그인 경로는 검증하지 못했습니다. 100점은 입력된 문제의 감점이 없다는 뜻이며, 미점검 영역이나 전체 사이트의 안전성을 보증하지 않습니다.

06 / CONTRIBUTION & REVIEW

직접 설명할 수 있는 프로젝트로

AI 지원 범위와 사용자 확인 전 항목을 분리했습니다. 사용자 독립 재현 후 개인 기여 기록을 확장합니다.

구분	현재 확인된 내용
김재민	목표·사용 흐름·입력 기반 분석·비공개 요구사항 정의
Codex 지원	웹앱·실습·테스트 구현, 자동 실행, 문서 생성
사용자 확인 전	코드 독해, 독립 실행, 직접 수정, 면접 설명
추가 검증 필요	실제 브라우저·모바일 확인, GitHub CI 실행

제출 패키지

프로젝트 PDF · GitHub 업로드용 소스 ZIP · README와 구조 문서 · 사례별 실행 증거 · 면접 예상 질문과 2분 시연 대본

비공개 사이트

Aegis Lab 프로젝트 사례 열기

사이트는 소유자 전용입니다. GitHub 업로드·외부 접근권한 변경·공개 전환은 수행하지 않았습니다. 시연 대본은 제공했으며 실제 브라우저 녹화 영상은 포함하지 않습니다.

참고 자료 · 2026.10.20 확인

[1] OWASP Authorization Cheat Sheet

[2] OWASP SQL Injection Prevention Cheat Sheet

[3] OWASP Session Management Cheat Sheet

자료의 기능·테스트 수치는 실제 실행 결과에 근거합니다. 프로젝트 자체 기준과 공식 참고 자료의 권고를 구분해 작성했습니다.